

Module 6: Distributed Security

6.1 Access Control Mechanisms

In a distributed environment, ensuring only authorized entities manipulate resources is paramount. There are two classic philosophies for this:

Mechanism	Where the Permission Lives	Analogy
Access Control List (ACL)	Attached directly to the resource, listing which users can read, write, or execute it.	A guest list held at the door of a venue.
Capability	Held by the user as a digital "ticket"; presenting it is enough to gain access.	A physical concert ticket — whoever holds it gets in.

ACLs make it easy to answer "who can access this resource?" (just look at the resource), while capabilities make it easy to transfer access (just hand over the ticket) but harder to audit or revoke, since the system may not know who currently holds a given capability.

6.2 Key Management in Distributed Environments

Cryptographic operations rely entirely on the secure distribution of keys.

Symmetric Keys and Kerberos

In symmetric-key cryptography, both parties share the same secret key, used for both encryption and decryption. **Kerberos** is the classic system for distributing these secrets safely, relying on a trusted third party called a **Key Distribution Center (KDC)**.

SIMPLIFIED KERBEROS TICKET FLOW

1. User logs in --> Authentication Server (AS)
Verifies identity, issues a Ticket-Granting Ticket (TGT).
2. User requests access to a specific service --> Ticket-Granting Server (TGS)
Checks the TGT, issues a Service Ticket for that service.
3. User presents Service Ticket --> The Service
Service grants access without ever seeing the user's original password again.

Asymmetric Keys and PKI

Public-Key Infrastructure (PKI) uses an asymmetric mathematical pair: a **public key** anyone can know, and a **private key** only the owner knows. Data encrypted with the public key can only be decrypted with the matching private key, and vice-versa. Trusted **Certificate Authorities (CAs)** issue **Digital Certificates** that bind a public key to a verified identity, forming a chain of trust: your browser trusts a root CA, that CA vouches for an intermediate CA, and the intermediate CA vouches for the website's certificate.

Feature	Symmetric (Kerberos-style)	Asymmetric (PKI-style)
Keys used	One shared secret key	A public/private key pair
Speed	Fast	Slower (more computation)
Key distribution problem	Must securely share the same key beforehand	Public key can be shared openly
Typical use	Internal networks, Kerberos tickets	HTTPS, digital certificates, email signing

6.3 Applied Cryptography

Cryptography provides three pillars of security:

- **Confidentiality:** via robust encryption — only authorized parties can read the data.
- **Integrity:** via cryptographic hashes — any tampering with the data changes its hash, revealing the tampering.
- **Authentication / Non-repudiation:** via digital signatures — proving who sent a message, and preventing them from later denying it.

■ How a Digital Signature Works, Step by Step

The sender computes a cryptographic hash of the message, then encrypts that hash using their own private key — this encrypted hash is the "signature." The receiver independently hashes the received message and decrypts the signature using the sender's public key. If the two hashes match, the receiver knows the message is both authentic (only the real sender's private key could have produced that signature) and unmodified in transit.

■ Key Takeaway

ACLs and capabilities answer "who is allowed in," while Kerberos and PKI answer "how do we prove identity and share secrets safely." Together, confidentiality, integrity, and authentication form the backbone of every secure distributed protocol you will encounter.

Glossary of Key Terms

Term	Meaning
ACL	Access Control List — permissions attached to the resource.
Capability	A transferable digital ticket that grants access to whoever holds it.
KDC	Key Distribution Center — the trusted third party in Kerberos.
CA	Certificate Authority — issues and vouches for digital certificates in PKI.
Digital signature	An encrypted hash used to prove authenticity and integrity.

What You Should Know

- The distinct differences between ACLs (resource-focused) and Capabilities (user-focused), and their respective trade-offs.
- How Kerberos facilitates secure authentication via a Key Distribution Center, including the TGT and Service Ticket flow.
- The role of Certificate Authorities in managing a Public-Key Infrastructure and the chain of trust.
- The three pillars of applied cryptography (confidentiality, integrity, authentication) and how a digital signature is created and verified.